

UNIMINUTO

Corporación Universitaria Minuto de Dios

Reporte de Solución de Problemas Matemáticos

Evaluación de la calidad del software mediante métricas, verificación y auditoría — Caso:
Sistema de Cargue de Documentos del FNA

Estudiante: [Jairo Alonso Cristancho]

Materia: Estándares y Métricas de Calidad en el Desarrollo de Software

Semana 2 — Aseguramiento de la calidad del software: validación, verificación, revisiones y auditorías

Docente: Cesar Alfonso Bolado Silva

Fecha de entrega: 13 de julio de 2026

1. Presentación del caso

El presente reporte desarrolla la actividad de la semana 2 de la materia Estándares y Métricas de Calidad en el Desarrollo de Software, adoptando el rol de especialista en aseguramiento de la calidad del software encargado de evaluar un sistema antes de su liberación a producción. Como caso de aplicación se utiliza el sistema de Cargue de Documentos del Fondo Nacional del Ahorro (FNA), un proyecto desarrollado bajo metodología ágil Scrum cuya finalidad es permitir que, desde el portal del Fondo, los consumidores financieros carguen documentos y que los funcionarios del FNA los visualicen, gestionen y notifiquen al usuario sobre el estado de su trámite.

A partir de la descripción de arquitectura del sistema y de las vulnerabilidades detectadas por el equipo de aseguramiento de calidad, se construyen a continuación el escenario, las evidencias, la matriz de verificación y validación, la lista de control de revisiones técnicas y el formato base de auditoría, siguiendo la estructura sugerida en el archivo de apoyo de la semana. El análisis se apoya en los principios de aseguramiento de la calidad del proceso de desarrollo de software (Chavarría et al., 2016) y en las guías de recomendación para la selección de modelos de mejora de procesos de software (Paredes et al., 2017).

2. Escenario del caso

2.1 Descripción general del sistema

El sistema de Cargue de Documentos del FNA es la solución que permite a los consumidores financieros (afiliados, cesantes y usuarios de crédito) cargar, desde el portal web del Fondo, los documentos requeridos para sus trámites (créditos de vivienda, cesantías, novedades, entre otros). Una vez cargado el documento, los funcionarios del FNA acceden a un módulo administrativo para visualizarlo, validarlo y gestionarlo, y el sistema notifica al usuario sobre el estado de su solicitud. El desarrollo y mantenimiento del sistema se gestiona bajo metodología Scrum, con entregas incrementales por sprint.

La arquitectura del sistema está compuesta, entre otros, por los siguientes elementos:

- FNAALOGSC01 (172.16.7.53): servidor de seguridad perimetral que controla el acceso a los servicios de cargue desde la red externa.
- BOGFWBPWSDC03 / BOGFWBPWSDC06: servidores Windows ubicados en la DMZ, con Apache Tomcat, que alojan los servicios carguedocumentos-cliente, carguedocumentos-web y el servicio SFTP.
- FNABOGGAPRO01: servidor Linux con GoAnywhere para transferencia segura de archivos vía SFTP.
- FNABOGSQAPP01: servidor Windows con SQL Server 2017 que aloja las bases de datos de cargue y notificaciones.
- FNABOGSRV: servidor de soporte de infraestructura.
- WebSphere Application Server 8.5 (AXCESA): aloja los clústeres con los módulos de cliente, administración y web del cargue de documentos.
- FNABOGWMP: broker de mensajes (WebSphere Message Broker 9) que maneja los flujos de obtención y consulta de documentos y requerimientos de crédito.
- FNABOGAPP08 / FNABOGAPP09: clústeres misionales COBIS (Créditos y Clientes), con WorkManager para procesos asíncronos.

- FNABOGPRT01 / 02 / 03 y FNABOGMDT: servidores de Active Directory y módulo de autenticación (APL/MicADInt) para el control de acceso.

El flujo general resumido del proceso es: el usuario carga el documento desde el portal → el servicio Tomcat en la DMZ recibe la solicitud → WebSphere (intranet) procesa la lógica de negocio → se integra con la base de datos, el ESB y COBIS → el documento se transfiere vía SFTP a GoAnywhere → la autenticación de los actores se valida contra Active Directory.

2.2 Contexto organizacional

- El sistema es administrado por el Fondo Nacional del Ahorro (FNA), entidad financiera de naturaleza pública, sujeta a regulación del sector financiero y de protección de datos personales en Colombia.
- El equipo de desarrollo trabaja bajo esquema ágil Scrum, con entregas incrementales por sprint y participación de un Product Owner, un Scrum Master y un equipo de desarrollo multidisciplinario.
- No se evidencia un área de aseguramiento de calidad independiente y consolidada; las validaciones de seguridad se han realizado de forma parcial durante los últimos sprints.
- Existe presión por mantener la disponibilidad continua del canal de cargue de documentos, dado su impacto directo en los tiempos de respuesta de trámites de crédito y cesantías.

2.3 Actores involucrados

- Consumidores financieros: afiliados y usuarios del FNA que cargan documentos desde el portal web para sus trámites.
- Funcionarios del FNA: personal administrativo que visualiza, valida y gestiona los documentos cargados, y da respuesta o notifica al usuario.
- Equipo de desarrollo Scrum: responsable de construir, probar y desplegar los módulos carguedocumentos-cliente, carguedocumentos-web y sus integraciones.
- Administrador de TI / Infraestructura: administra los servidores Tomcat, WebSphere, GoAnywhere, SQL Server y Active Directory.
- Oficial de seguridad de la información: responsable de la gestión de vulnerabilidades, hardening de servidores y cumplimiento normativo.
- Sistemas COBIS (Créditos y Clientes): sistemas core con los que se integra el proceso documental para validar información de crédito del usuario.

2.4 Funcionalidades críticas

- Cargue de documentos desde el portal web por parte del consumidor financiero.
- Visualización y gestión de documentos cargados por parte de los funcionarios del FNA.
- Notificación al usuario sobre el estado de su documento o trámite.
- Transferencia segura de archivos vía SFTP hacia el servidor GoAnywhere (FNABOGGAPRO01).
- Autenticación y control de acceso de funcionarios contra Active Directory.
- Integración con COBIS Créditos y Clientes para validar información asociada al trámite.
- Orquestación de flujos documentales a través del broker de mensajes (ESB).

2.5 Restricciones técnicas y regulatorias

- Ley 1581 de 2012 (Congreso de la República de Colombia, 2012) y Decreto 1377 de 2013 (Presidencia de la República de Colombia, 2013) — régimen general de protección de datos personales en Colombia, aplicable a los documentos e información de los consumidores financieros.
- Circulares y disposiciones de la Superintendencia Financiera de Colombia sobre seguridad y calidad de canales digitales para entidades financieras.
- Arquitectura híbrida entre DMZ (Tomcat) y red interna (WebSphere, SQL Server, COBIS, Active Directory), lo que exige controles de segmentación y hardening perimetral.
- Uso de protocolos de administración remota (SSH) sobre el servidor Linux GoAnywhere, sujeto a políticas de hardening de puertos.
- Dependencia de un antivirus corporativo instalado en los servidores del ecosistema, con cuentas de administración que deben cumplir el principio de mínimo privilegio.

2.6 Evidencias disponibles

Se cuenta con fragmentos de requisitos, un extracto de bitácora de incidencias de seguridad, una lista de control de cambios y resultados de pruebas preliminares, recopilados por el equipo de aseguramiento de calidad durante los últimos sprints, presentados a continuación.

2.6.1 Fragmento de especificación de requisitos

ID	Descripción	Tipo	Prioridad	Estado actual
RF-101	El portal debe permitir a los consumidores financieros cargar documentos en formatos PDF/JPG con validación de tamaño y tipo.	Funcional	Alta	Implementado
RF-102	Los funcionarios del FNA deben poder visualizar y gestionar los documentos cargados desde un módulo administrativo.	Funcional	Alta	Implementado
RF-103	El sistema debe notificar al usuario sobre el estado de su documento (recibido, en revisión, aprobado, rechazado).	Funcional	Alta	Implementado
RNF-104	Las respuestas HTTP de los servicios Tomcat en la DMZ deben incluir cabeceras de seguridad actualizadas (HSTS, CSP, X-Frame-Options, X-Content-Type-Options).	No funcional (seguridad)	Alta	Pendiente — cabeceras desactualizadas
RNF-105	El acceso administrativo del antivirus corporativo a los servidores debe realizarse con una cuenta de administrador dedicada y con privilegios mínimos.	No funcional (seguridad)	Alta	Pendiente — cuenta con privilegios excesivos
RNF-106	El servicio SSH del servidor GoAnywhere (FNABOGGAPRO01) debe operar sobre un puerto no estándar distinto del puerto 22.	No funcional (seguridad)	Alta	Pendiente — expuesto en puerto 22

ID	Descripción	Tipo	Prioridad	Estado actual
RNF-107	La transferencia y el almacenamiento de documentos cargados deben garantizar cifrado en tránsito y en reposo.	No funcional (seguridad)	Alta	Pendiente de verificación

2.6.2 Extracto de bitácora de incidencias

ID	Fecha	Módulo	Descripción	Severidad	Estado
INC-201	02/06/2026	Tomcat DMZ	Escaneo de seguridad evidenció ausencia de cabeceras HTTP de seguridad (HSTS, CSP, X-Frame-Options) en los servicios carguedocumentos-cliente y carguedocumentos-web.	Alta	Abierto
INC-202	05/06/2026	Antivirus / Infraestructura	La consola del antivirus corporativo opera con una cuenta de administrador (root) compartida entre varios integrantes del equipo de soporte, sin trazabilidad individual.	Alta	Abierto
INC-203	08/06/2026	GoAnywhere (SSH)	El servicio SSH del servidor FNABOGGAPRO01 permanece expuesto en el puerto estándar 22, facilitando su identificación por escaneos automatizados.	Alta	Abierto
INC-204	10/06/2026	SFTP / Transferencia	No se evidencia registro que confirme cifrado en reposo de los documentos almacenados tras la transferencia SFTP hacia GoAnywhere.	Media-Alta	Abierto
INC-205	12/06/2026	COBIS / Autenticación	No existen políticas documentadas de expiración de credenciales ni doble factor de autenticación para funcionarios que consultan documentos desde el módulo administrativo.	Media	Abierto

2.6.3 Lista de control de cambios

ID	Descripción del cambio	Módulo	Responsable	Revisado por	Aprobado / Estado
CR-301	Actualización de certificados TLS en balanceador de la DMZ.	Tomcat DMZ	Infraestructura	Líder técnico	Sí / Desplegado
CR-302	Ajuste de reglas de firewall perimetral (FNAALOGSC01).	Red / Perimetral	Infraestructura	No registrado	No / Desplegado
CR-303	Incorporación de nuevo flujo ESB para consulta de documentos.	WebSphere Message Broker	Dev Scrum	Líder técnico	Sí / Pendiente
CR-304	Cambio de credenciales de servicio SQL Server (carguedocumentos).	SQL Server	DBA	No registrado	No / Desplegado

Nota: se debe prestar especial atención a los cambios desplegados sin revisión ni aprobación registrada (CR-302 y CR-304), pues incrementan el riesgo de introducir fallas o brechas de seguridad no controladas.

2.6.4 Resultados de pruebas preliminares

Módulo	Tipo de prueba	Resultado	Observaciones
Cargue de documentos	Funcional	Aprobado	2 defectos menores de interfaz, corregidos.
Tomcat DMZ (cabeceras HTTP)	Seguridad (hardening)	Fallida	No se identifican HSTS, CSP, X-Frame-Options ni X-Content-Type-Options en las respuestas (ver INC-201).
Antivirus / gestión de accesos	Seguridad (privilegios)	Fallida	Cuenta de administrador del antivirus con privilegios excesivos y sin trazabilidad (ver INC-202).
GoAnywhere (SSH)	Seguridad (hardening de puertos)	Fallida	Puerto 22 expuesto; pendiente migración a puerto 2222 (ver INC-203).
Notificaciones al usuario	Funcional	Aprobado	Sin observaciones relevantes.
Integración COBIS	Integración	Aprobado con observaciones	No se probaron todos los escenarios de control de acceso por rol.

3. Identificación y justificación de hallazgos de seguridad

A partir del escenario y las evidencias anteriores, se identifican seis (6) hallazgos de seguridad relevantes para el sistema de Cargue de Documentos del FNA, cumpliendo con el mínimo de cinco (5) solicitados en la actividad.

Nº	Hallazgo	Justificación	Impacto
1	Cabeceras HTTP de seguridad desactualizadas en los servidores Tomcat de la DMZ (BOGFWPWSDC03/06).	Los escaneos de seguridad (INC-201) evidencian ausencia de HSTS, CSP, X-Frame-Options y X-Content-Type-Options en las respuestas de carguedocumentos-cliente y carguedocumentos-web.	Expone el portal a ataques de tipo XSS, clickjacking y degradación de conexión (downgrade a HTTP), afectando la confidencialidad e integridad de la sesión del consumidor financiero.
2	Cuenta de administrador (root) del antivirus corporativo con privilegios inadecuados y compartida entre el equipo de soporte.	INC-202 confirma que la consola del antivirus se administra con una cuenta compartida, sin trazabilidad individual ni aplicación del principio de mínimo privilegio.	Riesgo alto de escalamiento de privilegios y de acciones no atribuibles (desactivación de protección, exclusiones maliciosas) sobre servidores críticos de la arquitectura.
3	Exposición del servicio SSH en el puerto estándar 22 del servidor GoAnywhere (FNABOGGAPRO01).	INC-203 y la prueba de hardening confirman que el puerto 22 permanece activo, siendo el objetivo principal de escaneos automatizados y ataques de fuerza bruta.	Aumenta la superficie de ataque sobre el servidor que transfiere los documentos cargados;

N°	Hallazgo	Justificación	Impacto
			requiere migración a un puerto no estándar (2222) como medida de reducción de riesgo.
4	Falta de evidencia de cifrado en reposo de los documentos transferidos vía SFTP hacia GoAnywhere.	INC-204 indica que no existe registro que confirme el cifrado de los archivos almacenados tras la transferencia SFTP.	Compromete la confidencialidad de los documentos de los consumidores financieros ante un eventual acceso no autorizado al almacenamiento.
5	Ausencia de políticas de expiración de credenciales y de doble factor de autenticación para funcionarios que consultan documentos.	INC-205 evidencia que la autenticación contra Active Directory no exige rotación periódica de contraseñas ni MFA para el módulo administrativo.	Incrementa el riesgo de acceso indebido a documentos e información sensible de los usuarios por parte de cuentas comprometidas.
6	Cambios en producción sin revisión ni aprobación registrada (CR-302 y CR-304).	La lista de control de cambios evidencia modificaciones al firewall perimetral y a credenciales de base de datos sin responsable de revisión documentado.	Debilita la trazabilidad y el control de cambios, aumentando la probabilidad de introducir configuraciones inseguras sin detección oportuna.

4. Actividades de verificación y validación

Se diferencian las actividades de verificación (¿el sistema se construyó correctamente conforme a la especificación?) de las actividades de validación (¿el sistema construido satisface la necesidad real del consumidor financiero y del funcionario del FNA?), aplicadas a las funcionalidades críticas y a los hallazgos de seguridad identificados.

ID	Requisito / funcionalidad relacionada	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
RNF-104	Cabeceras de seguridad HTTP en Tomcat DMZ	Verificación	Revisión de configuración + escaneo de cabeceras HTTP	Oficial de seguridad	HSTS, CSP, X-Frame-Options y X-Content-Type-Options presentes en el 100% de las respuestas	Reporte de escaneo, configuración exportada
RNF-105	Gestión de privilegios de la cuenta de administrador del antivirus	Verificación	Revisión de accesos y de política de cuentas privilegiadas	Administrador de TI	Cuentas nominales, sin credenciales compartidas, con registro de auditoría	Acta de revisión de accesos, matriz de privilegios

ID	Requisito / funcionalidad relacionada	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
RNF-106	Migración del servicio SSH del puerto 22 al puerto 2222	Verificación	Escaneo de puertos + revisión de configuración sshd	Administrador de TI	Puerto 22 cerrado; servicio SSH operando exclusivamente en el puerto 2222	Reporte de escaneo de puertos, archivo de configuración
RNF-107	Cifrado en tránsito y en reposo de documentos cargados	Verificación	Inspección de configuración SFTP/GoAnywhere y del almacenamiento	Administrador de TI	Cifrado habilitado en tránsito (SFTP) y en reposo (AES-256 o equivalente)	Evidencia de configuración de cifrado
RF-101 / RF-102	Cargue y visualización de documentos por consumidores y funcionarios	Validación	Pruebas orientadas al usuario (UAT) con consumidores financieros y funcionarios	Product Owner / equipo Scrum	El usuario logra cargar y el funcionario logra visualizar el documento sin errores en el 100% de los casos de prueba	Actas de UAT, casos de prueba ejecutados
RF-103	Notificación al usuario sobre el estado del documento	Validación	Pruebas orientadas al usuario end-to-end	Product Owner / equipo Scrum	El usuario recibe notificación correspondiente al estado real del trámite en el 100% de los casos	Registros de notificación, evidencias de UAT
CR-302 / CR-304	Cambios en producción sin aprobación registrada	Verificación	Auditoría de la bitácora de control de cambios	Oficial de seguridad	100% de los cambios en producción con responsable de revisión documentado	Bitácora de cambios actualizada

5. Lista de control de revisiones técnicas (checklist)

Checklist de revisión técnica compuesto por doce (12) ítems, superando el mínimo de diez (10) solicitados, elaborado a partir del escenario del sistema de Cargue de Documentos del FNA.

Nº	Ítem de revisión	Cumple (Sí/No/N.A.)	Observaciones / evidencia
1	Las respuestas HTTP de los servicios Tomcat en la DMZ incluyen cabeceras de seguridad actualizadas (HSTS, CSP, X-Frame-Options, X-Content-Type-Options).	No	Ver INC-201
2	La cuenta de administrador del antivirus corporativo cumple el principio de mínimo privilegio y no es compartida.	No	Ver INC-202
3	El servicio SSH del servidor GoAnywhere opera en un puerto distinto al 22 (recomendado: 2222).	No	Ver INC-203

Nº	Ítem de revisión	Cumple (Sí/No/N.A.)	Observaciones / evidencia
4	Los documentos cargados se transfieren y almacenan con cifrado en tránsito y en reposo.	N.A.	Pendiente de verificación (INC-204)
5	Los mecanismos de autenticación y autorización protegen adecuadamente el módulo administrativo de funcionarios.	No	Sin MFA ni expiración de credenciales (INC-205)
6	Existe trazabilidad entre los requisitos funcionales y no funcionales y los casos de prueba ejecutados.	N.A.	Pruebas de seguridad incompletas
7	Todos los cambios en producción cuentan con revisión y aprobación documentada.	No	CR-302 y CR-304 sin responsable de revisión
8	El código fuente de los módulos carguedocumentos-cliente y carguedocumentos-web cumple los estándares de codificación del equipo Scrum.	Sí	Revisión de código en sprint
9	La segmentación entre la DMZ (Tomcat) y la red interna (WebSphere, SQL Server, COBIS) restringe adecuadamente el tráfico.	N.A.	Pendiente de auditoría de firewall
10	Existen registros de auditoría (logs) para los accesos y modificaciones realizados por los funcionarios sobre los documentos.	N.A.	No confirmado en el escenario
11	El manejo de datos personales del consumidor financiero cumple con la Ley 1581 de 2012 y su reglamentación.	N.A.	Pendiente de verificación jurídica
12	El proceso de notificación al usuario refleja de forma consistente el estado real del documento o trámite.	Sí	Aprobado en pruebas funcionales

6. Plan y formato base de auditoría

6.1 Datos generales

Campo	Contenido
Objetivo de la auditoría	Evaluar el cumplimiento de los controles de seguridad y calidad del sistema de Cargue de Documentos del FNA antes de su liberación a producción, con énfasis en cabeceras HTTP, gestión de privilegios administrativos, hardening de puertos y protección de documentos de los consumidores financieros.
Alcance	Servicios carguedocumentos-cliente y carguedocumentos-web (Tomcat DMZ), servidor GoAnywhere (SFTP/SSH), consola de administración del antivirus corporativo, integración con Active Directory y bases de datos de cargue y notificaciones (SQL Server).
Criterios de auditoría (normas/estándares de referencia)	ISO/IEC 25010 (calidad del producto de software), Ley 1581 de 2012 y Decreto 1377 de 2013, buenas prácticas de hardening (OWASP Secure Headers, CIS Benchmarks) y políticas internas de gestión de accesos privilegiados del FNA.
Equipo auditor	Especialista en aseguramiento de la calidad del software (rol asumido en este reporte), con apoyo del oficial de seguridad de la información.
Fecha de ejecución	13 de julio de 2026

Campo	Contenido
Evidencias a recolectar	Bitácora de incidencias, lista de control de cambios, resultados de pruebas de seguridad, reportes de escaneo de cabeceras HTTP y de puertos, matriz de privilegios administrativos del antivirus.

6.2 Hallazgos de auditoría

Nº	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Cabeceras de seguridad HTTP ausentes en Tomcat DMZ.	Buenas prácticas OWASP Secure Headers	INC-201, prueba de hardening fallida	Alta	Configurar HSTS, CSP, X-Frame-Options y X-Content-Type-Options en BOGFWPWSDC03/06 antes del despliegue.
2	Cuenta de administrador del antivirus con privilegios excesivos y compartida.	Política de mínimo privilegio	INC-202	Alta	Crear cuentas nominales con privilegios diferenciados y habilitar auditoría de acciones.
3	Puerto SSH 22 expuesto en GoAnywhere.	CIS Benchmarks / hardening de puertos	INC-203	Alta	Migrar el servicio SSH al puerto 2222 y restringir el acceso mediante firewall y listas blancas de IP.
4	Sin evidencia de cifrado en reposo de documentos.	Ley 1581 de 2012 (protección de datos)	INC-204	Media-Alta	Habilitar y documentar cifrado en reposo (AES-256 o equivalente) en el almacenamiento de GoAnywhere.
5	Cambios en producción sin aprobación registrada.	Política interna de gestión de cambios	CR-302, CR-304	Media	Formalizar el flujo de aprobación de cambios (change management) previo a todo despliegue en producción.

6.3 Conclusión general de la auditoría

El sistema de Cargue de Documentos del FNA presenta funcionalidades críticas operativas y aprobadas funcionalmente; sin embargo, evidencia brechas relevantes en materia de hardening de seguridad (cabeceras HTTP, puerto SSH), gestión de privilegios administrativos y control de cambios, que deben remediarse antes de considerar el sistema apto para producción sin riesgo residual alto.

6.4 Firma

Auditor	Fecha
Jairo Alonso Cristancho	13 de julio de 2026

7. Estándar de calidad aplicado: ISO/IEC 25010

Se selecciona la norma ISO/IEC 25010 (International Organization for Standardization, 2011) como referencia para evaluar la calidad del producto de software, dado que ofrece un modelo de características aplicable tanto a los aspectos funcionales como a los no funcionales identificados en el escenario del FNA.

- Seguridad: aplica directamente a los hallazgos 1, 2, 3, 4 y 5 (cabeceras HTTP, privilegios del antivirus, puerto SSH, cifrado y autenticación), evaluando confidencialidad, integridad, no repudio, responsabilidad y autenticidad.
- Fiabilidad: relacionada con la disponibilidad del canal de cargue de documentos y la tolerancia a fallos ante incidentes de infraestructura.
- Adecuación funcional: cubre el cargue, la visualización y la notificación de documentos conforme a las necesidades del consumidor financiero y del funcionario del FNA.
- Mantenibilidad: aplicable al control de cambios (CR-302, CR-304) y a la trazabilidad del código en un esquema de desarrollo Scrum con entregas incrementales.
- Compatibilidad: relevante para la integración entre Tomcat, WebSphere, el ESB, COBIS, SQL Server y Active Directory.

8. Definición de métricas de calidad

Se definen seis (6) métricas, superando el mínimo de cinco (5) solicitadas, alineadas con los atributos de calidad de ISO/IEC 25010 y con los hallazgos de seguridad identificados.

Métrica	Atributo ISO/IEC 25010	Fórmula / forma de medición	Criterio de aceptación	Fuente
Cobertura de cabeceras de seguridad HTTP	Seguridad	$(\text{N.º de cabeceras de seguridad implementadas} / \text{N.º de cabeceras requeridas}) \times 100$	100 % antes del paso a producción	Escaneo de cabeceras HTTP
Cumplimiento de mínimo privilegio en cuentas administrativas	Seguridad	$(\text{N.º de cuentas administrativas nominales y auditadas} / \text{N.º total de cuentas administrativas}) \times 100$	$\geq 95 \%$	Matriz de privilegios / auditoría de accesos
Exposición de puertos críticos	Seguridad	N.º de servicios críticos (SSH, RDP, DB) expuestos en puertos estándar por defecto	0 servicios en puertos estándar (SSH migrado a 2222)	Escaneo de puertos
Disponibilidad del servicio de cargue de documentos	Fiabilidad	$(\text{Tiempo operativo del servicio} / \text{Tiempo total del periodo evaluado}) \times 100$	$\geq 99,5 \%$	Monitoreo de infraestructura
Tasa de cambios no autorizados en producción	Mantenibilidad	$(\text{N.º de cambios sin aprobación registrada} / \text{N.º total de cambios desplegados}) \times 100$	0 %	Lista de control de cambios
Tiempo medio de notificación al usuario	Adecuación funcional	Suma de tiempos entre la revisión del funcionario y el envío de la notificación / N.º de notificaciones	≤ 4 horas hábiles	Registros de notificación

9. Conclusiones y recomendaciones priorizadas

9.1 Conclusiones

1. El sistema de Cargue de Documentos del FNA cumple con sus funcionalidades críticas de negocio (cargue, visualización y notificación), pero presenta brechas de seguridad significativas que deben cerrarse antes de considerar el sistema listo para producción sin riesgo residual alto.
2. Los hallazgos con mayor severidad (cabeceras HTTP desactualizadas, privilegios excesivos del antivirus y exposición del puerto SSH 22) corresponden a debilidades de hardening que son de remediación relativamente rápida y de alto impacto en la reducción del riesgo.
3. La falta de control formal sobre los cambios en producción (CR-302, CR-304) evidencia una debilidad de gobierno de TI que trasciende el sistema evaluado y debe abordarse a nivel de proceso.
4. La aplicación de ISO/IEC 25010, junto con la matriz de verificación y validación y el checklist de revisión técnica, permitió estructurar de forma objetiva la evaluación de calidad y priorizar los hallazgos según su severidad e impacto.

9.2 Recomendaciones priorizadas

5. Prioridad alta — Configurar de inmediato las cabeceras de seguridad HTTP (HSTS, CSP, X-Frame-Options, X-Content-Type-Options) en los servidores Tomcat de la DMZ.
1. Prioridad alta — Migrar el servicio SSH del servidor GoAnywiere (FNABOGGAPRO01) del puerto 22 al puerto 2222, y restringir el acceso mediante firewall y listas blancas de IP.
2. Prioridad alta — Eliminar la cuenta de administrador compartida del antivirus corporativo y establecer cuentas nominales con privilegios mínimos y auditoría de acciones.
3. Prioridad media — Confirmar y documentar el cifrado en tránsito y en reposo de los documentos cargados por los consumidores financieros.
4. Prioridad media — Formalizar el proceso de gestión de cambios (change management), exigiendo revisión y aprobación registrada para todo despliegue en producción.
5. Prioridad media — Implementar doble factor de autenticación y políticas de expiración de credenciales para los funcionarios que acceden al módulo administrativo de documentos.
6. Prioridad baja — Evaluar, a mediano plazo, la incorporación de algoritmos y herramientas de minería de procesos (Urrea-Contreras et al., 2020) para el monitoreo continuo de los flujos documentales entre Tomcat, WebSphere, el ESB y COBIS, facilitando la detección temprana de desviaciones operativas.

10. Referencias

- Chavarría, A., Oré, S., & Pastor, C. (2016). Aseguramiento de la calidad en el proceso de desarrollo de software utilizando CMMI, TSP y PSP. *RISTI – Revista Ibérica de Sistemas e Tecnologias de Informação*, 2016(20), 62–77. <https://doi.org/10.17013/risti.20.62-77>
- Congreso de la República de Colombia. (2012, 17 de octubre). *Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales*. Diario Oficial No. 48.587. <https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981>

- International Organization for Standardization. (2011). *Systems and software engineering — Systems and software quality requirements and evaluation (SQuaRE) — System and software quality models* (ISO/IEC 25010:2011). <https://www.iso.org/standard/35733.html>
- Paredes, L., Benavides, L., & Sánchez, N. (2017). Guía de recomendación para la selección de un modelo de calidad para la mejora de procesos de software (SPI). *Revista Ciencias Estratégicas*.
- Presidencia de la República de Colombia. (2013, 27 de junio). *Decreto 1377 de 2013. Por el cual se reglamenta parcialmente la Ley 1581 de 2012*. Diario Oficial No. 48.834. <https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=53646>
- Urrea-Contreras, S., Flores-Rios, B., Astorga-Vargas, M., Ibarra-Esquer, J., González-Navarro, F. F., Velazquez-Solis, P., & Albarracín, C. A. Ardila. (2020). Propuesta de un marco de trabajo para la identificación y selección de algoritmos y herramientas de minería de procesos orientado a las organizaciones de desarrollo de software. *RISTI – Revista Ibérica de Sistemas e Tecnologias de Informação*, (25), 348–363.